# Analyse des risques et architecture de sécurité

**AGR-1481 / CYBER-G2**
Gridone 0.307.0 - Produit et déploiement sur un site client type

Ce dossier décrit les actifs, frontières de confiance et chemins d’attaque de Gridone. Il propose une architecture de zones/conduits, un registre de risques priorisé, des objectifs vérifiables et un plan d’essais utilisable sur banc.

| Référence | Valeur |
|---|---|
| Version examinée | Commit f0fe7c89fbe28e23e0b80b828f3cc81de316f681 ; lecture le 08/10/2026. |
| Hypothèse de déploiement | Site tertiaire en France ; instance locale, régulation autonome dans les automates, frontal HTTPS. Aucun site réel identifié. |
| Statut | Version 0.1 pour revue. Cotations et niveaux cibles proposés ; aucun risque accepté, aucun essai exécuté. |
| Document amont | AGR-1480 / CYBER-G1 : applicabilité, responsabilités, contrôles B01-B16 et ANSSI R1-R26. |
| Révision à déclencher | Nouveau site, transport, application, driver sensible, topologie, incident ou mise à jour modifiant la sécurité. |

## Priorités issues de l’analyse

Réduire le risque de commandes non autorisées ; maîtriser l’identité et les sessions ; isoler les protocoles hérités ; protéger secrets et confiance ; limiter les requêtes sortantes ; prouver la reprise et la traçabilité. Les conséquences physiques restent à préciser avec l’exploitant.

Ce travail est une analyse documentaire structurée, inspirée de l’approche zones/conduits. Ce n’est ni une étude IEC 62443-3-2 approuvée clause par clause, ni une homologation, ni une analyse de sûreté certifiée.

# 01 / Actifs et conséquences métier

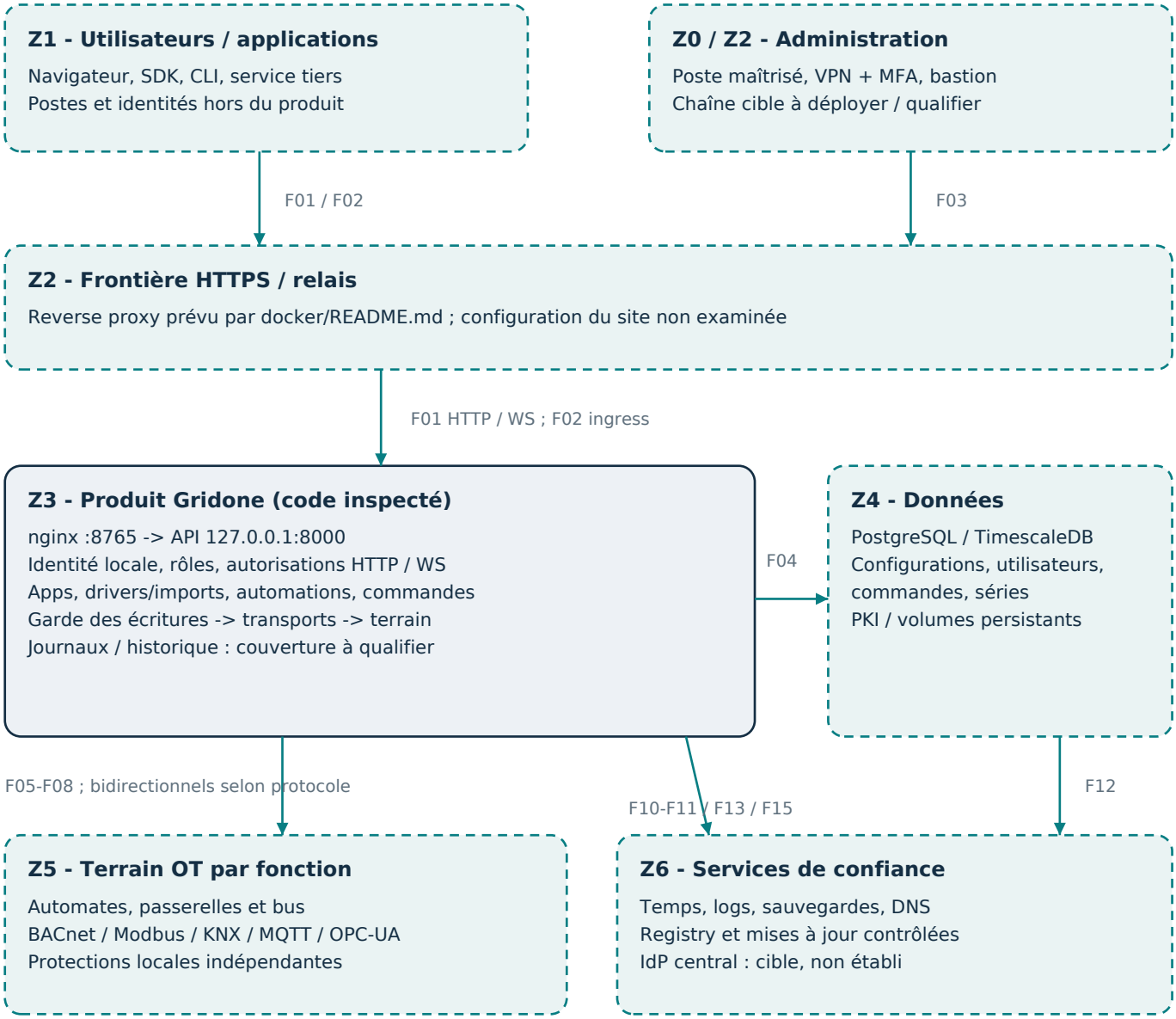
| Actif / valeur | Conséquence redoutée | Responsable de validation |
|---|---|---|
| A01 - Consignes et commandes | Dérive CVC, consommation, inconfort ; dommage matériel ou sanitaire selon fonction réellement raccordée. | Exploitant + ingénieur OT |
| A02 - Mesures et fraîcheur | Mauvaise décision automatique ou humaine si donnée fausse, rejouée ou périmée. | Exploitant |
| A03 - Drivers, règles, automations | Adresse ou unité erronée ; contournement de contrainte ; diffusion d'une erreur à plusieurs équipements. | Produit + intégrateur |
| A04 - Identités, rôles, sessions | Impersonation, privilèges excessifs, persistance après fin d'intervention. | RSSI client + produit |
| A05 - Secrets et PKI | Usurpation d'instance/passerelle et accès durable au réseau terrain. | Produit + intégrateur |
| A06 - Hôte, API, DB et stockage | Arrêt de supervision, exfiltration, perte de configuration ou pivot interzone. | Intégrateur |
| A07 - Traces et références de temps | Actions non attribuables ; détection et investigation dégradées. | RSSI client |
| A08 - Sauvegardes et mises à jour | Reprise impossible ; réintroduction d'une version compromise. | Exploitant + produit |
| A09 - Contrôleurs, bus et réseau OT | Altération du fonctionnement local ; propagation au-delà de la supervision. | Intégrateur + fournisseur |

## Hypothèses à valider

**H1 :** les boucles locales et protections restent autonomes sans Gridone. **H2 :** la supervision n'assure pas une fonction de sécurité des personnes. **H3 :** les protections HTTPS, bastion et segmentation sont à qualifier sur le site. **H4 :** il existe un accès de récupération local contrôlé. **H5 :** les fournisseurs documentent l'état sûr des équipements.

Si H1 ou H2 est fausse, les cotations de gravité et les objectifs proposés ne suffisent plus : réanalyse OT obligatoire avant action. Les usages hospitaliers, ECS à enjeu sanitaire, désenfumage ou continuité électrique nécessitent une étude par fonction.

# 02 / Frontières de confiance




Trait plein : composants lus dans le dépôt. Cadre pointillé : zone ou service de déploiement proposé, présence et séparation non vérifiées sur site. Les flèches indiquent les échanges fonctionnels ; les règles détaillées figurent dans la matrice des conduits.

**Point d’attention :** nginx et l’API partagent le conteneur ; une frontière de code n’est pas une isolation réseau. Le mode réseau host supprime l’isolation réseau habituelle du conteneur : binding, pare-feu hôte, routes et sorties doivent être vérifiés. [C07-C08]

# 03 / Zones et profils de confiance

| Zone / contenus | Règle proposée | Risques principaux |
|---|---|---|
| Z0 - Extérieur non maîtrisé | Internet, prestataires, fournisseurs. Aucune route directe vers un automate ou une base. | RK01,08,10,15 |
| Z1 - Utilisateurs / apps | Clients autorisés mais données d'entrée non fiables. Apps externes isolées selon leurs droits ; aucun accès implicite au terrain. | RK02,03,10,11 |
| Z2 - Accès et administration | Frontal HTTPS et chaîne VPN/MFA/bastion ; management distinct de l'exploitation. Journaliser et limiter dans le temps. | RK01,08,12 |
| Z3 - Supervision Gridone | API et services produit ; orchestration et transports. Egress limité aux conduits approuvés. Exécution avec privilèges minimaux. | RK04,06,10,17,20 |
| Z4 - Données et PKI | Base, volumes, secrets et sauvegardes actives. Accès par identités dédiées ; ni lecture libre utilisateur ni accès Internet. | RK04,13,14 |
| Z5.x - Terrain par fonction | Sous-zones CVC, énergie, éclairage, etc. à préciser. Isoler l'héritage et les passerelles ; conserver la régulation locale. | RK05,07,09,16,17 |
| Z6 - Services de confiance | Temps, DNS, collecte, sauvegardes hors ligne, mises à jour. Droits séparés ; compromission d'un service sans autorité totale. | RK13,14,15,18 |

Ce découpage décrit des domaines de confiance à matérialiser. Il n'affirme pas l'existence de sept VLAN. Un service colocalisé conserve un périmètre de droits distinct ; la séparation des hôtes s'arbitre selon criticité, coût et possibilités du site.

## Autorité et responsabilité

Le RSSI client approuve les flux et l'architecture ; l'intégrateur matérialise les frontières ; le produit documente les capacités et limites. L'exploitant valide les échanges indispensables et le comportement dégradé. Les fournisseurs prouvent les protections natives des contrôleurs.

La découverte BACnet et les bus série constituent des chemins spécifiques. Aucun relais de broadcast généralisé n'est implicite ; ports, équipements cibles et opérations doivent être listés.

# 04 / Matrice des conduits (1/3)

Matrice de conception ; adresses, ports effectifs, processus source, fréquence et propriétaire nominatif à renseigner par l'intégrateur.

Les conduits F01-F16 décrivent les échanges à qualifier. Les constats C01-C16 renvoient au catalogue de code en annexe. Les directions ne représentent pas des règles déjà déployées.

## F01 / UI/SDK/CLI, API et WS

Z1 -> Z2 -> Z3

HTTPS/WSS frontal ; hop HTTP local maîtrisé. JWT, droits serveur, filtrage par rôle. Entrées : consignes, configuration ; sorties : données.
**Rattachement :** constat C02,constat C03,constat C08,constat C15 ; RK01-03,08

## F02 / Ingress transport / topic

Source externe -> Z3

Route indépendante du JWT ; bearer/HMAC selon transport. Profil cible : auth obligatoire, anti-rejeu, débit et 1 Mio maximum.
**Rattachement :** constat C09 ; RK09,11,20

## F03 / Administration / maintenance

Prestataire -> Z2 -> hôte/OT

VPN + MFA + bastion ; identité nominative, ticket, durée limitée. Ports outils exacts à inventorier ; jamais d'accès général.
**Rattachement :** ANSSI R1-R6 ; RK01,08,12

## F04 / Données / configurations

Z3 -> Z4

Connexion DB par rôle dédié ; TLS si interhôte, restriction réseau et stockage. Port et paramètres réels à confirmer.
**Rattachement :** constat C04 ; RK04,14,20

## F05 / BACnet/IP et Modbus

Z3 <-> Z5.x

Lecture/écriture autorisées par équipement/fonction. Héritage contenu. Découverte limitée ; pas de FD ni écriture administrative implicite.
**Rattachement :** B10,R7,R26 ; RK07,08,17

## F06 / MQTT

Z3 <-> broker -> Z5.x

TLS avec validation ; identité et ACL par topic. Authentification du broker et des producteurs. Le broker relaie mesures/commandes.
**Rattachement :** constat C05 ; RK05,07,09

# 04 / Matrice des conduits (2/3)

Matrice de conception ; adresses, ports effectifs, processus source, fréquence et propriétaire nominatif à renseigner par l'intégrateur.

Les conduits F01-F16 décrivent les échanges à qualifier. Les constats C01-C16 renvoient au catalogue de code en annexe. Les directions ne représentent pas des règles déjà déployées.

## F07 / OPC-UA / KNX

Z3 <-> Z5.x

Politique sûre activée, confiance provisionnée, identité et droits. Ne pas confondre protection du réseau IP et protection du bus final.
**Rattachement :** constat C06,B10 ; RK05,09

## F08 / HTTP, gateways, bus physiques

Z3 -> endpoints / série

Destinations et méthodes approuvées ; sortie filtrée et TLS si possible. Chemin série documenté, droits OS et accès physique contrôlés.
**Rattachement :** constat C10 ; RK07,10,12

## F09 / Apps / callbacks / configuration

Z3 <-> Z1 application

Demandes publiques d'enregistrement, approbation, service account ; HTTP sortant vers api_url. Ne pas déléguer des droits excessifs.
**Rattachement :** constat C10,constat C14 ; RK03,10,11

## F10 / Logs, métriques, alertes

Z3/Z4/OT -> Z6

Transport protégé, capacité tampon, réduction des données sensibles. Retour du collecteur sans droit de commande.
**Rattachement :** B12,R13,R18 ; RK04,13,20

## F11 / DNS et temps

Hôte/OT -> Z6

Sources approuvées ; dérive détectée. Résolution des endpoints soumise aux règles egress ; temps utilisé pour preuves et certificats.
**Rattachement :** B06,B12 ; RK05,10,13

# 04 / Matrice des conduits (3/3)

Matrice de conception ; adresses, ports effectifs, processus source, fréquence et propriétaire nominatif à renseigner par l'intégrateur.

Les conduits F01-F16 décrivent les échanges à qualifier. Les constats C01-C16 renvoient au catalogue de code en annexe. Les directions ne représentent pas des règles déjà déployées.

## F12 / Sauvegarde / restauration

Z4 -> dépôt sauvegarde

Identité distincte, chiffrement et copie hors ligne. Chemin inverse uniquement en restauration autorisée, avec contrôle d'intégrité.
**Rattachement :** B13 ; RK14

## F13 / Installation / mise à jour

Registry -> hôte / produit

Téléchargement contrôlé, digest et signature vérifiés à destination ; rollback approuvé. Le code de publication seul n'impose pas le contrôle local.
**Rattachement :** constat C13,B14 ; RK15,18

## F14 / Drivers / imports / règles

Admin -> Z3

Permissions, format borné, version et revue avant effet sur les adresses/écritures. Les imports ne sont pas des sources de confiance.
**Rattachement :** constat C11,constat C12 ; RK06,17

## F15 / Identité centralisée cible

Z3 -> IdP éventuel

Intégration non établie dans les chemins inspectés. À ajouter seulement après définition du protocole, disponibilité et accès de secours.
**Rattachement :** B01 ; RK01,16

## F16 / USB, console, BIOS, alimentation

Local physique -> hôte/OT

Poste maîtrisé, accès physique limité, sas de médias et règles de reprise. Conduit physique distinct du filtrage IP.
**Rattachement :** R19-R21 ; RK12,16

# 05 / Opérations privilégiées

| Opération | Frontière et contrôle à vérifier | Risque / preuve |
|---|---|---|
| Comptes, rôles, blocage, reset | Identité humaine -> API -> service users ; permission et audit ; révocation des sessions associées. | RK01-03 / T01-T03 |
| Transports / secrets / reconnexion | Admin -> API -> transports ; droit d'édition, données sensibles write-only, pas de repli silencieux. | RK04-05 / T04,T05 |
| Drivers / présentation / import | Admin -> parseur -> données de commande ; provenance, bornes, impacts et version. | RK06 / T06 |
| Consigne unitaire, lot, template | API -> sélection -> service commandes -> garde -> transport ; autorisation, destinataires figés, revalidation. | RK03,17 / T03,T13 |
| Automations / règles d'exploitation | Édition privilégiée puis exécution de fond ; acteur, version, droits et justification de l'acquittement d'un état inconnu. | RK06,17 / T06,T13 |
| Découverte / reconnexion terrain | Opérateur autorisé -> transport ; segment et budget bornés, impact réseau évalué. | RK07,20 / T07,T16 |
| App acceptée / activation / config | Admin -> registre app -> callbacks ; intention connue, URL permise, permissions minimales et expiration. | RK03,10,11 / T03,T08,T09 |
| Déploiement / DB / restauration / PKI | Admin du site -> hôte ou base ; séparation des tâches, sauvegarde préalable, validation de signature et traces. | RK04,14,15 / T04,T11,T12 |

La présence de require_permission et d'une garde applicative ne démontre pas l'exhaustivité de tous les chemins. La couverture des API, tâches automatiques et outils de maintenance doit être prouvée par T03/T13. Les protections logicielles de Gridone ne remplacent aucun interverrouillage matériel.

# 06 / Méthode de cotation

Échelle qualitative proposée pour ce dossier ; elle ne prétend pas reproduire une méthode IEC complète. Chaque risque décrit une menace, un actif, des préconditions, un effet et les protections observées. La cotation initiale tient compte des protections de code observées mais ne suppose aucune protection site non vérifiée.

| Vraisemblance V | Interprétation | Impact I | Interprétation |
|---|---|---|---|
| 1 - Faible | Plusieurs prérequis maîtrisés et accès rare. | 1 - Limité | Gêne locale rapidement récupérable. |
| 2 - Possible | Accès restreint ou action préparatoire nécessaire. | 2 - Modéré | Perte partielle d’un service ou données limitées. |
| 3 - Plausible | Chemin accessible à un acteur interne, app ou attaquant muni d’un compte. | 3 - Majeur | Arrêt de supervision ou altération significative du fonctionnement. |
| 4 - Élevée | Exposition directe / répétabilité avec protection faible vérifiée. | 4 - Critique | Impact physique/sanitaire possible ou atteinte étendue au SI. |

## Calcul et traitement

Score = V × I. 1-3 : faible ; 4-7 : modéré ; 8-11 : élevé ; 12-16 : critique. Les conséquences critiques sont des hypothèses de scénario à confirmer avec le site, pas des constats de danger établi. La confiance de la cotation est moyenne pour les chemins de code, faible pour les conséquences et l’exposition du site.

Les valeurs « résiduel cible » représentent une estimation **conditionnelle à l’application et à la réussite des tests**. Elles ne décrivent pas le risque actuel et ne valent pas acceptation. Toute gravité I=4 nécessite une décision explicite de l’exploitant/ingénieur OT même si la vraisemblance estimée diminue.

## Règles d’admission proposées

Aucun risque critique non traité ; risque élevé soumis à revue contradictoire et mesures compensatoires ; risques modérés/faibles avec propriétaire. Les limites physiques inconnues, une restauration non prouvée ou une frontière réseau non vérifiée bloquent le pilote correspondant.

Ne pas calculer de probabilité annuelle ou de perte financière à partir de cette échelle ordinale. Réévaluer après inventaire AGR-1482, observation du site et retours d’essai.

# 07 / Registre des risques (1/5)

Cotation proposée ; résiduel cible uniquement après contrôles et tests. Aucun risque n’est clos.

## RK01 / Prise de contrôle d’un compte privilégié

A04/A01 ; conduits F01,F03,F15 | Initial 3×4=12 | Résiduel cible 1×4=4, non accepté
Pilote : RSSI client + produit (titulaire à nommer)

Identifiant volé, faible secret ou poste distant compromis ; authentification locale observée, MFA central non établi. V3 : accès par utilisateur/app plausible ; I4 : consignes sensibles possibles selon site.
**Traitement :** Comptes nominatifs, MFA, anti-essais, bastion et secours maîtrisé.
**Références :** B01,B04 ; AGR-1483,1485,1509 ; constats C01,C02.
**Vérification :** T01,T14 ; traces de refus et retrait. Preuve attendue E/RK01.

## RK02 / Session réutilisable après départ

A04/A07 ; F01 | Initial 3×3=9 | Résiduel cible 1×3=3, non accepté
Pilote : Produit (titulaire à nommer)

Refresh réutilisé ou session ouverte après logout/changement de droits. Logout cookie-only et JWT stateless dans les chemins lus ; WS borné à exp. V3 : vol/rejeu plausible ; I3 : accès prolongé.
**Traitement :** Révocation serveur et rotation unique ; clôture HTTP/WS lors du retrait d’accès.
**Références :** B02 ; AGR-1484 ; constats C02,C03.
**Vérification :** T02 ; preuve de retrait dans le délai O02. Preuve attendue E/RK02.

## RK03 / Élévation ou abus d’un droit légitime

A01/A03/A04 ; F01,F09,F14 | Initial 2×4=8 | Résiduel cible 1×4=4, non accepté
Pilote : Produit + RSSI (titulaire à nommer)

Compte ou app avec droits trop larges ; mutation par lot ou automation. RBAC présent, couverture totale non prouvée. V2 : compte nécessaire ; I4 : commandes groupées possibles.
**Traitement :** Matrice de permissions, périmètre du compte de service et contrôle de chaque chemin.
**Références :** B03,B04 ; AGR-1486,1487 ; constats C14,C15.
**Vérification :** T03 ; matrice d’autorisations et refus. Preuve attendue E/RK03.

## RK04 / Exposition de secrets et clés privées

A05/A06 ; F04,F10,F12 | Initial 3×4=12 | Résiduel cible 1×4=4, non accepté
Pilote : Produit + intégrateur (titulaire à nommer)

Lecture DB/config, export ou logs ; masquage déclaré ne vaut pas chiffrement et clé MQTT non marquée secret. V3 : multiples voies ; I4 : usurpation durable.
**Traitement :** Cycle de vie des secrets, chiffrement, clés séparées, droits minimaux et redaction complète.
**Références :** B05,B07 ; AGR-1488,1490,1492 ; constats C04,C05.
**Vérification :** T04 ; canaris absents API/logs/export, rotation et reprise. Preuve attendue E/RK04.

# 07 / Registre des risques (2/5)

Cotation proposée ; résiduel cible uniquement après contrôles et tests. Aucun risque n’est clos.

## RK05 / Usurpation d’un serveur ou confiance dégradée

A05/A09 ; F06,F07,F11 | Initial 2×4=8 | Résiduel cible 1×4=4, non accepté
Pilote : Intégrateur + produit (titulaire à nommer)

Attaque lors du premier contact OPC-UA, option de validation réduite ou certificat expiré. V2 : position réseau nécessaire ; I4 : mesures/écritures falsifiées.
**Traitement :** Provisionnement hors canal, interdiction du downgrade, renouvellement planifié.
**Références :** B06,B10 ; AGR-1489,1496,1501 ; constats C05,C06.
**Vérification :** T05 ; imposteur rejeté et renouvellement validé. Preuve attendue E/RK05.

## RK06 / Driver ou configuration malveillante

A01/A03 ; F14 | Initial 2×4=8 | Résiduel cible 1×4=4, non accepté
Pilote : Produit + intégrateur (titulaire à nommer)

Import/édition modifie adresses, codecs, unités ou contraintes. Parsing borné présent mais provenance et revue métier non prouvées. V2 : privilège/import requis ; I4 : action sur mauvaise destination.
**Traitement :** Versionner, approuver, comparer les effets et revalider les commandes en attente.
**Références :** B11,B14 ; AGR-1504,1512 ; constats C11,C12.
**Vérification :** T06 ; import rejeté / changement invalidant preview. Preuve attendue E/RK06.

## RK07 / Injection directe sur un protocole hérité

A01/A09 ; F05,F08 | Initial 3×4=12 | Résiduel cible 1×4=4, non accepté
Pilote : Intégrateur + exploitant (titulaire à nommer)

Équipement compromis ou accès au segment BACnet/Modbus ; absence d’authentification native de l’îlot. V3 : segmentation inconnue ; I4 : écriture terrain hors API.
**Traitement :** Isoler l’îlot, limiter interlocuteurs et fonctions, surveiller ; migration ou exception à durée bornée.
**Références :** B10 ; AGR-1495,1497,1498,1499 ; constats C05,C08.
**Vérification :** T07 ; flux refusés et écritures métier conservées. Preuve attendue E/RK07.

## RK08 / Pivot de Gridone vers IT ou autres zones

A06/A09 ; F01,F03,F04,F05 | Initial 3×4=12 | Résiduel cible 1×4=4, non accepté
Pilote : Intégrateur + produit (titulaire à nommer)

Hôte compromis, API HTTP exposée ou droits OS étendus ; réseau host et absence de USER dans l’image. V3 : frontières non attestées ; I4 : extension de compromission.
**Traitement :** Moindre privilège, proxy/binding sûrs, filtrage d’entrée/sortie et absence de pont interzone.
**Références :** B07,B08 ; AGR-1490,1491,1508 ; constats C07,C08.
**Vérification :** T07,T14 ; UID, règles hôte et conduits inspectés. Preuve attendue E/RK08.

# 07 / Registre des risques (3/5)

Cotation proposée ; résiduel cible uniquement après contrôles et tests. Aucun risque n’est clos.

## RK09 / Mesure fausse, rejouée ou périmée

A02/A01 ; F02,F05-F08 | Initial 3×4=12 | Résiduel cible 1×4=4, non accepté
Pilote : Produit + exploitant (titulaire à nommer)

Faux producteur, bus compromis ou ancien événement. Fraîcheur logicielle présente ; authenticité terrain et anti-rejeu non prouvés. V3 : sources multiples ; I4 : décision de régulation erronée.
**Traitement :** Authentifier sources, anti-rejeu, expiration des observations et réactions par fonction.
**Références :** B10,B11,B15 ; AGR-1494,1495,1507 ; constats C09,C16.
**Vérification :** T09,T13 ; donnée invalide exclue de la décision. Preuve attendue E/RK09.

## RK10 / Requête sortante vers un service interdit

A06/A05 ; F08,F09,F11 | Initial 2×4=8 | Résiduel cible 1×4=4, non accepté
Pilote : Produit + intégrateur (titulaire à nommer)

URL driver/app provoque un appel interne inattendu ou fuite ; client HTTP sans allowlist observée. V2 : configuration contrôlable nécessaire ; I4 : accès aux services de confiance.
**Traitement :** Allowlist adaptée à l’OT, validation résolution/redirection et pare-feu egress. Ne pas bannir tous les réseaux privés légitimes.
**Références :** B09 ; AGR-1493 ; constats C10,C14.
**Vérification :** T08 ; endpoint interdit injoignable malgré variations d’URL. Preuve attendue E/RK10.

## RK11 / Abus d’ingress ou d’enregistrement public

A02/A06 ; F02,F09 | Initial 3×3=9 | Résiduel cible 1×3=3, non accepté
Pilote : Produit (titulaire à nommer)

Push signé rejoué, mode none ou création massive de demandes. Limite 1 Mio présente, anti-rejeu/quotas non établis. V3 : entrée accessible ; I3 : données ou capacité dégradées.
**Traitement :** Auth obligatoire par profil, quotas et anti-rejeu ; validation de l’origine des demandes.
**Références :** B09,B15 ; AGR-1494,1506 ; constats C09,C14.
**Vérification :** T09,T16 ; refus et maintien de disponibilité. Preuve attendue E/RK11.

## RK12 / Compromission par poste ou accès physique

A06/A09 ; F03,F16 | Initial 2×4=8 | Résiduel cible 1×4=4, non accepté
Pilote : Intégrateur + exploitant (titulaire à nommer)

USB, console, BIOS ou armoire accessibles ; protections site inconnues. V2 : accès local requis ; I4 : persistance ou reprogrammation.
**Traitement :** Postes durcis, sas, ports/UEFI et accès locaux maîtrisés, interventions nominatives.
**Références :** R1,R9,R19-R21 ; AGR-1510 ; constats Site non évalué.
**Vérification :** T15 ; contrôles physiques et media inoffensif. Preuve attendue E/RK12.

# 07 / Registre des risques (4/5)

Cotation proposée ; résiduel cible uniquement après contrôles et tests. Aucun risque n’est clos.

## RK13 / Effacement des preuves ou temps incohérent

A07 ; F10,F11 | Initial 3×3=9 | Résiduel cible 1×3=3, non accepté
Pilote : RSSI client + produit (titulaire à nommer)

Suppression locale, collecteur indisponible ou dérive d’horloge. Historique métier présent, chaîne d’audit exhaustive non établie. V3 : administration locale possible ; I3 : incident indétectable/non attribuable.
**Traitement :** Collecte distante protégée, accès séparés, intégrité et alertes de rupture/dérive.
**Références :** B12,B16 ; AGR-1502,1503 ; constats C11.
**Vérification :** T10 ; reconstruction d’une chronologie et alerte. Preuve attendue E/RK13.

## RK14 / Rançongiciel ou restauration incomplète

A06/A08 ; F04,F12 | Initial 2×4=8 | Résiduel cible 1×4=4, non accepté
Pilote : Exploitant + intégrateur (titulaire à nommer)

Données et sauvegardes accessibles au même compte ; clés ou projets automates absents de la copie. V2 : compromission préalable ; I4 : reprise prolongée.
**Traitement :** Copies isolées, clés récupérables sous contrôle séparé et test de restauration intégral.
**Références :** B13 ; AGR-1505 ; constats Site non évalué.
**Vérification :** T11 ; récupération mesurée RTO/RPO. Preuve attendue E/RK14.

## RK15 / Mise à jour substituée ou retour mal maîtrisé

A03/A06/A08 ; F13 | Initial 2×4=8 | Résiduel cible 1×4=4, non accepté
Pilote : Produit + intégrateur (titulaire à nommer)

Image ou dépendance compromise, contrôle de signature ignoré au déploiement. Signature publication observée. V2 : chaîne/administration requise ; I4 : code hostile au cœur OT.
**Traitement :** SBOM, verrouillage du digest, vérification destination et rollback qualifié sans incohérence de données.
**Références :** B14 ; AGR-1513,1514 ; constats C13.
**Vérification :** T12 ; rejet image non approuvée, rollback restauré. Preuve attendue E/RK15.

## RK16 / Perte d’identité, cloud, réseau ou alimentation

A01/A06/A09 ; F03,F11,F15,F16 | Initial 3×4=12 | Résiduel cible 1×4=4, non accepté
Pilote : Exploitant + intégrateur (titulaire à nommer)

Dépendance externe ou perte hôte ; autonomie et redondance du site inconnues. V3 : panne plausible ; I4 : fonction métier interrompue si H1 fausse.
**Traitement :** Fonctions locales indépendantes, accès de secours et redémarrage contrôlé ; objectifs métier explicites.
**Références :** B15,R8 ; AGR-1507,1508 ; constats C08,C16.
**Vérification :** T14 ; coupures sur banc et contrôle d’autonomie. Preuve attendue E/RK16.

# 07 / Registre des risques (5/5)

Cotation proposée ; résiduel cible uniquement après contrôles et tests. Aucun risque n’est clos.

## RK17 / Commande périmée ou incohérente au retour

A01/A03 ; F01,F05-F08,F14 | Initial 2×4=8 | Résiduel cible 1×4=4, non accepté
Pilote : Produit + exploitant (titulaire à nommer)

Preview, règle, destinataire ou valeur change avant exécution/reconnexion. Liaison de preview et garde présentes ; cas de reprise à qualifier. V2 ; I4 : action tardive ou collective.
**Traitement :** Revalider au moment de l’écriture, expirer les commandes selon fonction, tracer tout acquittement d’inconnu.
**Références :** B11,B15 ; AGR-1504,1507 ; constats C11,C16.
**Vérification :** T13 ; changement et perte/reprise sans écriture non voulue. Preuve attendue E/RK17.

## RK18 / Équipement vulnérable ou hors support oublié

A08/A09 ; F05-F08,F13 | Initial 3×3=9 | Résiduel cible 1×3=3, non accepté
Pilote : Intégrateur + produit (titulaire à nommer)

Version inconnue, correctif non suivi ou fournisseur sans engagement. V3 : inventaire incomplet non exclu ; I3 : exposition prolongée.
**Traitement :** Inventaire fiable, veille, maintenance et délais selon risque ; remplacements documentés.
**Références :** B14 ; AGR-1482,1511,1515 ; constats Site non évalué.
**Vérification :** T17 ; avis rapproché d’une version et d’un responsable. Preuve attendue E/RK18.

## RK19 / Exfiltration de données de bâtiment

A02/A04/A06 ; F01,F09,F10 | Initial 2×3=6 | Résiduel cible 1×3=3, non accepté
Pilote : RSSI client + produit (titulaire à nommer)

Rôle/app ou export trop large divulgue occupation, contacts et topologie. Filtrage de lecture observé, minimisation/rétention site inconnue. V2 ; I3 : atteinte aux personnes et renseignement d’attaque.
**Traitement :** Minimiser exports et collecte, isoler périmètres et définir conservation et habilitations.
**Références :** B03,B05,B12 ; AGR-1487,1492,1502 ; constats C04,C15.
**Vérification :** T03,T04 ; contrôle export et collecte. Preuve attendue E/RK19.

## RK20 / Saturation de l’API, du terrain ou du stockage

A01/A06/A09 ; F01,F02,F05-F10 | Initial 3×3=9 | Résiduel cible 1×3=3, non accepté
Pilote : Produit + intégrateur (titulaire à nommer)

Charge volumétrique, diffusion, polling ou commandes nombreuses. Bornes ponctuelles présentes mais capacité pilote inconnue. V3 : requêtes répétables ; I3 : supervision dégradée.
**Traitement :** Budgets par API/transport, concurrence et quotas, seuils d’alerte ; protéger les tâches essentielles.
**Références :** B15 ; AGR-1506 ; constats C09,C11,C16.
**Vérification :** T16 ; charge bornée et maintien du service prioritaire. Preuve attendue E/RK20.

# 08 / Objectifs opérationnels proposés

Les valeurs ci-dessous sont des critères de départ pour un banc tertiaire non critique. Elles ne sont ni des performances mesurées ni des SLA contractuels. Les objectifs marqués « à définir » sont des **bloquants explicites** de la recette concernée.

| ID / mesure | Cible ou décision nécessaire | Validation / test |
|---|---|---|
| O01 - Autorisation | 100 % des chemins privilégiés couverts ; aucun accès inter-rôle interdit accepté. | Produit / T03 |
| O02 - Retrait d'accès | HTTP et WS révoqués en ≤ 60 s ; refresh retiré non réutilisable. Inactivité humaine proposée : 15 min. | RSSI + produit / T02 |
| O03 - Commande API | Accusé de prise en charge p95 ≤ 2 s sur charge approuvée ; distinguer acceptation et réalisation physique. | Produit + exploitant / T13,T16 |
| O04 - Action physique | Délai maximal, fréquence et bornes de consigne : À DÉFINIR par fonction et automate. Aucun seuil thermique générique. | Ingénieur OT / bloque essais terrain |
| O05 - Donnée périmée | Pour mesure non critique : seuil candidat ≤ 2 périodes d'acquisition, plafond 60 s. Ajuster aux capteurs lents ; décision inconnue explicite. | Exploitant / T13 |
| O06 - Commande différée | Durée maximale et autorisation de rejeu : À DÉFINIR par fonction. Critère commun : zéro écriture non validée au retour. | Exploitant / T13,T14 |
| O07 - Reprise supervision | Hypothèse de travail : RTO ≤ 4 h ; RPO ≤ 24 h. Ne convient pas à une fonction critique sans étude. | Exploitant / T11 |
| O08 - Fonction autonome | Perte de supervision : aucune perte de protection locale ; durée d'autonomie exigée À DÉFINIR. | Ingénieur OT / T14 |
| O09 - Logs et temps | Cible pilote : écart d'horloge ≤ 1 s ; événement au collecteur ≤ 60 s ; alerte de rupture ≤ 5 min. | RSSI + intégrateur / T10 |
| O10 - Perte du collecteur | Tampon candidat ≥ 24 h ; rétention candidate 90 j au collecteur. Actions à arrêter/maintenir si tampon plein : À DÉFINIR. | RSSI + exploitant / T10,T16 |
| O11 - Charge et maintenance | Nombre d'actifs, polling, commandes/s, marge et fenêtre de maintenance : À DÉFINIR avant test de capacité. | Intégrateur + exploitant / T16 |

Les gardes applicatives existantes utilisent leurs propres règles de fraîcheur ; O05 ne présume pas qu'un paramètre global correspondant existe. Chaque cible doit être traduite en configuration ou changement logiciel vérifiable.

# 09 / Cibles de sécurité par zone

Proposition à discuter sur la base des risques, et non conclusion de conformité IEC. L'hypothèse SL-T 2 vise à traiter les attaques intentionnelles opportunistes envisagées. Le vecteur suit FR1 à FR7. Aucune capacité SL-C ni atteinte SL-A n'est attestée. [S8-S10]

| Zone | Hypothèse de cible | Justification et décision |
|---|---|---|
| Z2 - Accès / administration | (2,2,2,2,2,2,2) à valider | Point de contrôle privilégié ; RK01,RK08,RK12. MFA/bastion et séparation à prouver. |
| Z3 - Supervision | (2,2,2,2,2,2,2) à valider | Commande et orchestration ; RK03,RK04,RK06,RK10,RK17. Capacités produit encore partielles. |
| Z4 - Données / PKI | (2,2,2,2,2,2,2) à valider | Usurpation durable, traces et reprise ; RK04,RK13,RK14. Contrôles de stockage et récupération nécessaires. |
| Z5 - Terrain non critique | (2,2,2,2,2,2,2) comme objectif système | RK07,RK09,RK16 ; capacités natives parfois insuffisantes. Mesures compensatoires et limites à démontrer. |
| Z5 - Fonction critique éventuelle | À déterminer ; aucune cible numérique approuvée | Conséquence physique non caractérisée. Analyse dédiée pouvant imposer un objectif plus élevé ; pas de SL3 automatique. |
| Z6 - Services de confiance | (2,2,2,2,2,2,2) à valider | Intégrité des preuves, mise à jour et reprise ; RK13-RK15. Comptes et chemins séparés. |
| Z0/Z1 - Extérieur / clients | Aucun niveau attribué par ce dossier | Sources considérées non fiables ; les contrôles se placent aux frontières d'accès. |

**Conduits :** F01-F04 et F09-F15 doivent satisfaire les exigences approuvées des zones qu'ils relient. Pour F05-F08 hérités, le tunnel ou le pare-feu ne confère pas une capacité cryptographique au bus aval. F16 exige des contrôles physiques et organisationnels.

Le responsable sécurité et le spécialiste IEC doivent confirmer chaque composante du vecteur, les clauses exactes et la tolérance au risque. L'acceptation appartient au propriétaire du système avec l'exploitant ; elle ne peut être déduite d'une simple moyenne des scores.

# 10 / Scénarios de vérification (1/3)

Tous les scénarios sont **non exécutés**. Les environnements utilisent des émulateurs, équipements d'essai et identifiants dédiés. Chaque preuve E/Txx contient versions, configuration, attendu/observé et relecteur.

## T01 / Identité / accès privilégié

RK01 / B01

Sur environnement de test, compte nominatif, MFA attendu et essais invalides à débit maîtrisé.
**Réussite :** Accès refusé sans facteur requis ; anti-essais mesuré ; compte initial remplacé.

## T02 / Révocation HTTP et WS

RK02 / B02

Ouvrir une session puis retirer l'accès ; essayer refresh et conserver le flux ouvert.
**Réussite :** Toutes les voies cessent ≤ O02 ; jeton retiré non réutilisable.

## T03 / Droits, lectures et mutations

RK03,19 / B03

Matrice admin/opérateur/viewer/service ; routes, lots, exports, règles et automations.
**Réussite :** Zéro succès d'une opération interdite ; pas de données hors périmètre.

## T04 / Secrets

RK04,19 / B05

Injecter uniquement des canaris non sensibles ; parcourir API/export/logs/backup et rotation.
**Réussite :** Canaris absents des sorties interdites ; restauration avec clés contrôlées.

## T05 / Confiance transport

RK05 / B06

Simuler certificat inconnu, expiré, mauvaise identité, renouvellement autorisé et mode faible.
**Réussite :** Refus explicite des variantes interdites ; aucun downgrade automatique.

## T06 / Drivers et configuration

RK06 / B11

Import de fixture, changement de version/adresse/règle entre preview et confirmation.
**Réussite :** Input invalide refusé ; préparation périmée invalidée ; modification attribuable.

# 10 / Scénarios de vérification (2/3)

Tous les scénarios sont **non exécutés**. Les environnements utilisent des émulateurs, équipements d'essai et identifiants dédiés. Chaque preuve E/Txx contient versions, configuration, attendu/observé et relecteur.

## T07 / Frontières et héritage

RK07,08 / B08,B10

Configuration d'abord ; en banc, flux représentatifs permis/interdits, fonctions industrielles bornées.
**Réussite :** Tout flux hors matrice refusé ; maintien des écritures métier autorisées.

## T08 / Sorties HTTP

RK10 / B09

Cibles simulées autorisées/interdites, variations DNS/URL et redirections selon politique.
**Réussite :** Aucune connexion vers une destination interdite ; résultat journalisé.

## T09 / Push et rejeu

RK09,11 / B09

Émettre message authentifié, sans auth, dupliqué, périmé et corps au-delà du plafond.
**Réussite :** Refus/rejeu sans effet métier ; donnée fausse non utilisée.

## T10 / Traces et temps

RK13 / B12

Action/refus, arrêt du collecteur, dérive de temps simulée et reprise.
**Réussite :** Chronologie reconstituable ; alerte et tampon selon O09/O10.

## T11 / Restauration

RK14 / B13

Copie protégée vers environnement vierge, avec DB, configuration, PKI et projet automate simulé.
**Réussite :** Fonctions reprises ; intégrité, RTO/RPO et récupération des clés prouvés.

## T12 / Mise à jour / rollback

RK15 / B14

Image approuvée puis image non approuvée et retour à version supportée sur banc.
**Réussite :** Signature/digest exigés ; refus sûr ; reprise sans incohérence.

# 10 / Scénarios de vérification (3/3)

Tous les scénarios sont **non exécutés**. Les environnements utilisent des émulateurs, équipements d'essai et identifiants dédiés. Chaque preuve E/Txx contient versions, configuration, attendu/observé et relecteur.

## T13 / Fraîcheur / commande différée

RK09,17 / B11,B15

Donnée expirée, référence cassée, configuration changée, reconnexion et confirmation répétée.
**Réussite :** Zéro écriture hors politique ; destinataire correct ; délais O03-O06 mesurés.

## T14 / Pannes et accès de secours

RK01,08,16 / B15

Perdre successivement WAN, IdP éventuel, DB, réseau OT et alimentation simulée.
**Réussite :** Comportement validé par fonction, alarmes et retour contrôlé ; autonomie O08.

## T15 / Poste / média / physique

RK12 / R1,R19-R21

Revue de configuration et raccordement encadré d'un média ou terminal inoffensif.
**Réussite :** Accès non autorisé bloqué ; sas, poste et UEFI démontrés.

## T16 / Charge bornée

RK11,20 / B15

Palier progressif sur émulateurs ; débit API, polling, lots et stockage, limites d'arrêt convenues.
**Réussite :** Objectifs tenus sous charge retenue ; backpressure, alertes et reprise propres.

## T17 / Avis de vulnérabilité

RK18 / B14

Bulletin fictif sur version connue du pilote ; désigner instances et mainteneurs.
**Réussite :** Inventaire permet de cibler et décider mitigation/correctif avec délai approuvé.

# 11 / Pannes et conditions de test

| Événement | Comportement attendu à confirmer | Condition de reprise |
|---|---|---|
| WAN / cloud / IdP perdu | Boucles locales indépendantes ; aucune authentification de secours implicite. Accès local d’urgence nominatif, borné et tracé. | Vérifier identité, temps, qualité des données ; retirer le secours. |
| DB indisponible | Signaler la dégradation ; aucune commande déclarée durable/traçable sans preuve. Politique de continuité des écritures à arbitrer selon fonction. | Réconcilier états avant reprise ; pas de duplication d’ordre. |
| Transport ou réseau OT perdu | Marquer la qualité des observations ; ne pas considérer une ancienne mesure comme fraîche ; alarmes adaptées. | Acquérir de nouvelles observations et revalider avant écriture. |
| Collecteur de logs perdu | Tampon local et alerte ; politique de restriction des actions privilégiées lorsque la traçabilité n’est plus assurée. | Exporter sans perte ni doublon ambigu ; vérifier chronologie. |
| Certificat / heure invalide | Refus explicite et alerte ; pas de désactivation automatique de vérification. | Remettre confiance/temps via procédure approuvée. |
| Redémarrage / perte électrique | Protections du contrôleur indépendantes ; commandes anciennes non rejouées aveuglément. | Restaurer confiance dans les mesures, configuration et consentements. |

## Garde-fous du banc et du pilote

Le banc ne commande aucun équipement exploité. Avant un pilote : liste signée des actifs/adresses, créneau, responsable présent, état initial sauvegardé, méthode, conditions d’arrêt, retour arrière et moyen d’intervention local. Contrôler la frontière physique du banc avant de démarrer.

Arrêt immédiat en cas de mouvement/action inattendue, alarme de sûreté, perte de communication hors périmètre, dérive d’une consigne ou seuil de charge dépassé. Les valeurs de seuil sont fixées par l’exploitant ; aucune injection sur un automate en production n’est autorisée par ce document.

# 12 / Traitement des risques résiduels

Aucun risque n’a été accepté dans cette version. Pour chaque RKxx, le pilote prépare les preuves, puis le propriétaire du système décide avec le RSSI et l’exploitant. Le produit atteste ses capacités ; il ne peut accepter à la place du client un risque sur le fonctionnement du bâtiment.

| Champ de décision | Contenu à renseigner |
|---|---|
| Identité | RKxx ; contrôle Bxx/Rx ; actif, site, version, conduit et scénario. |
| Appréciation | Cotation initiale révisée, preuve des contrôles, cotation résiduelle et justification. |
| Décision | Réduire / éviter / transférer contractuellement / accepter explicitement ; impact physique examiné. |
| Compensation | Filtrage, isolement, supervision humaine, accès réduit, limitation fonctionnelle ; mode dégradé décrit. |
| Responsabilité | Nom du propriétaire, relecteur sécurité, validateur exploitation, date de décision. |
| Durée | Échéance d’expiration obligatoire ; événement déclenchant un retrait anticipé. |
| Contrôle | Test à rejouer, preuve attendue et condition de réouverture. |

## Exemple de dérogation à instruire

Un automate Modbus conservé dans un îlot isolé ne peut pas chiffrer ses échanges. Le projet pourrait proposer : seule l’instance identifiée peut l’atteindre ; fonctions et registres métier explicitement autorisés ; accès d’ingénierie hors exploitation ; détection des opérations atypiques ; remplacement planifié. Cette description n’est pas une dérogation accordée. Elle doit être liée à RK07, à une preuve T07, à un titulaire et à une date d’expiration.

## Blocages de la validation

Site et fonctions non identifiés ; criticité physique inconnue ; titulaires et dates absents ; objectifs O04/O06/O08/O11 non fixés ; clauses IEC non examinées sous licence ; architecture et essais non approuvés. Ces points bloquent la validation G2 et le pilote correspondant, pas la préparation documentaire.

# 13 / Validation et traçabilité

| Critère de l’issue AGR-1481 | Éléments disponibles | À obtenir |
|---|---|---|
| Entrées/sorties et opérations privilégiées | 16 conduits ; matrice des opérations ; risques RK01-RK20. | Confirmation d’exhaustivité avec topologie et inventaire du site. |
| Registre de risques complet | Scénarios, rationale V/I, rôles, traitements, tests et résiduels cibles. | Titulaire nominatif, cotation revue, résultat des contrôles et acceptation. |
| Schéma zones/conduits signé | Schéma de référence et frontières produit/site explicités. | Plan as-built, correspondances actifs/adresses et signatures. |
| Limites disponibilité et sûreté | O01-O11 ; valeurs candidates et blocages explicités. | Valeurs par fonction, approbation exploitation et scénario de test associé. |
| Tests d’actionnement maîtrisés | Garde-fous et règles d’arrêt documentés. | Procédure pilote approuvée ; aucun essai réel réalisé. |

## Ordre de travail proposé

1. Valider G1 et nommer les responsables.
2. Renseigner l’inventaire pilote avec AGR-1482 et confirmer les hypothèses H1-H5.
3. Revoir les risques critiques RK01/RK04/RK07/RK08/RK09/RK16 et les limites physiques.
4. Approuver zones, conduits, cibles et critères ; construire le banc AGR-1517.
5. Exécuter les tests, corriger, re-tester puis décider les résiduels avant AGR-1518/1519.

## Visa à recueillir

Architecte produit : périmètre et chemins de commande.
Ingénieur OT et exploitant : fonctions, effets physiques, autonomie et objectifs.
Intégrateur : architecture effective et faisabilité des conduits.
RSSI client / propriétaire du système : priorités, résiduels et admission.

**État de livraison :** documentation locale préparée, non signée. Les issues Linear conservent leur état ; une conclusion de sécurité nécessite les décisions et preuves ci-dessus.

# Annexe A / Références du code (1/2)

Catalogue des constats C01-C16 partagé avec G1. Il s’agit de preuves de lecture, pas de résultats d’exécution.

## C01 - Mots de passe et bootstrap

packages/users/src/users/validation.py
packages/users/src/users/password.py

## C02 - Sessions HTTP

packages/users/src/users/auth.py
packages/api/src/api/routes/users/auth_router.py

## C03 - WebSocket et rôles

packages/api/src/api/auth.py
packages/api/src/api/routes/websocket.py

## C04 - Confidentialité des secrets

packages/devices_manager/src/devices_manager/storage/transport_record.py
packages/devices_manager/src/devices_manager/dto/transport_dto.py

## C05 - Modes de transport

packages/devices_manager/src/devices_manager/core/transports/mqtt_transport/transport_config.py

## C06 - Confiance OPC-UA

packages/devices_manager/src/devices_manager/core/transports/opcua_transport/security.py

## C07 - Image et privilèges

docker/Dockerfile
docker/supervisord.conf

## C08 - Frontière HTTPS

docker/README.md
docker/nginx.conf.template

# Annexe A / Références du code (2/2)

Catalogue des constats C01-C16 partagé avec G1. Il s’agit de preuves de lecture, pas de résultats d’exécution.

## C09 - Ingress public

packages/api/src/api/routes/transports_router.py
packages/devices_manager/src/devices_manager/core/transports/webhook_transport/auth.py

## C10 - Requêtes sortantes

packages/devices_manager/src/devices_manager/core/transports/http_transport/client.py
packages/apps/src/apps/apps_manager.py

## C11 - Garde et historique des commandes

packages/commands/src/commands/service.py
packages/api/src/api/selection_commands.py

## C12 - Imports et parsing

packages/models/src/models/yaml_loader.py
packages/devices_manager/src/devices_manager/core/presentation/package.py

## C13 - Publication des images

.github/workflows/release.yml

## C14 - Applications externes

packages/api/src/api/routes/apps/registration_router.py
packages/apps/src/apps/registration_service.py

## C15 - Autorisations

packages/api/src/api/auth.py
packages/api/src/api/access/policy.py

## C16 - Mesures et disponibilité

packages/devices_manager/src/devices_manager/core/device/trust_expiry.py
packages/operating_rules/src/operating_rules/guard.py

# Annexe B / Sources et vocabulaire

Références primaires et documents de travail utilisés. La description du code correspond au commit du 08/10/2026. Le rapport initial a été corrigé dans G1 ; ses affirmations ne sont pas réputées normatives.

**S1.** ANSSI-PA-110, v1.0 du 27/04/2026. Licence ouverte Etalab v2.0 ; adaptation contextualisée, sans validation ANSSI.

**S3.** ANSSI - Directive NIS2. Consulté le 08/10/2026.

**S7.** IEC 62443-4-1:2018. Fiche publique uniquement ; clauses complètes non consultées.

**S8.** IEC 62443-4-2:2019. Fiche publique uniquement ; clauses complètes non consultées.

**S9.** IEC 62443-3-2:2020. Fiche publique uniquement ; clauses complètes non consultées.

**S10.** IEC 62443-3-3:2013. Fiche publique uniquement ; clauses complètes non consultées.

**S11.** IEC 62443-2-4:2023. Fiche publique uniquement ; clauses complètes non consultées.

**S12.** Issues et feuille de route Cyber Compliance. Consulté le 08/10/2026.

## Vocabulaire

**OT :** équipements et systèmes qui commandent le fonctionnement physique du bâtiment. **Zone :** actifs partageant des exigences de sécurité. **Conduit :** échanges contrôlés entre zones. **RTO :** durée maximale visée de reprise. **RPO :** perte maximale visée de données dans le temps. **IdP :** fournisseur d’identité. **SL-T :** niveau de sécurité cible ; **SL-C :** capacité ; **SL-A :** niveau atteint à démontrer.

**Notation :** Axx = actifs ; Fxx = conduits ; Cxx = constats de code ; RKxx = risques ; Bxx/Rx = contrôles de G1 ; Oxx = objectifs ; Txx = tests. Les preuves E/… sont des emplacements logiques à créer lors de l’exécution.